

VAPT Internship

Week 10 Assignment Report

Topic: IDS/IPS/Firewall Evasion & Malware Analysis

Submitted by

Sulav Adhikari

VAPT Internship Program

June 2026

Table of Contents

Table of Contents	i
Task 1 – IDS/IPS/Firewall Evasion Research	1
1.1 What is IDS, IPS, and Firewall?	1
1.1.1 Intrusion Detection System (IDS)	1
1.1.2 Intrusion Prevention System (IPS)	1
1.1.3 Firewall	1
1.2 Differences Between IDS, IPS, and Firewall	2
1.3 Common Evasion Techniques	3
1.3.1 Packet Fragmentation	3
1.3.2 Traffic Obfuscation	4
1.3.3 Protocol Tunneling	5
1.3.4 Encryption-based Evasion	5
1.3.5 Port Hopping	6
1.3.6 Traffic Padding	7
Task 2 – Malware Analysis Fundamentals	9
2.1 Malware Categories – Comparative Table	9
2.2 Detailed Descriptions	10
2.2.1 Virus	10
2.2.2 Worm	10
2.2.3 Trojan	10
2.2.4 Ransomware	10
2.2.5 Spyware	11
2.2.6 Rootkit	11
2.2.7 Botnet Malware	11
Task 3 – Static Malware Analysis	12
3.1 Selected Sample	12
3.2 File Hashes	12
3.3 Associated Indicators of Compromise (IOCs)	12
3.4 Behavioral Characteristics	12
3.5 MITRE ATT&CK Techniques	13
Task 4 – Threat Intelligence Mapping	14
4.1 Selected Malware Family: LockBit 3.0	14
4.2 MITRE ATT&CK Full Mapping Table	14
Bonus Task – Real-World Malware Campaign Analysis	16

Campaign: MOVEit Transfer Mass Exploitation by Cl0p Ransomware Group (2023)	16
Targeted Industry	16
Infection Vector	16
Impact.....	16
Detection Opportunities	16
Defensive Recommendations	17
References and Sources.....	18

Task 1 – IDS/IPS/Firewall Evasion Research

1.1 What is IDS, IPS, and Firewall?

1.1.1 Intrusion Detection System (IDS)

An Intrusion Detection System (IDS) is a passive security monitoring tool that analyses network traffic and system activities to identify potential threats, policy violations, or malicious behaviour. It operates by comparing observed activity against known attack signatures or baselines of normal behaviour, then raises alerts for human or automated review. Because an IDS only detects and reports, it does not actively block or terminate traffic.

IDS solutions are classified into two primary types:

- Network-based IDS (NIDS) – deployed at strategic points in the network (e.g., behind the perimeter firewall) to monitor all passing traffic. Examples include Snort and Suricata.
- Host-based IDS (HIDS) – installed on individual endpoints to monitor local system calls, file integrity, log files, and process activity. Examples include OSSEC and Tripwire.

1.1.2 Intrusion Prevention System (IPS)

An Intrusion Prevention System (IPS) is an active, inline security control that not only detects malicious traffic but also takes immediate automated action to block, drop, or redirect it before it reaches the target. Because it sits directly in the traffic path (inline mode), any failure in the IPS can disrupt legitimate connectivity, so high availability and low latency are critical design requirements.

IPS operates using three key detection mechanisms:

- Signature-based detection – matches traffic against a database of known attack patterns.
- Anomaly-based detection – flags deviations from an established baseline of normal behaviour.
- Policy-based detection – enforces predefined security rules regardless of known signatures.

1.1.3 Firewall

A firewall is a network security device (hardware or software) that monitors and controls incoming and outgoing network traffic based on a predefined set of security rules. Firewalls act as the first line of defence, establishing a barrier between trusted internal networks and untrusted external networks such as the Internet.

Common firewall types include:

- Packet-filtering firewall – inspects packets at the network layer and allows or blocks based on IP addresses, ports, and protocols.
- Stateful inspection firewall – tracks the state of active connections and makes decisions based on the context of traffic flow.
- Next-Generation Firewall (NGFW) – performs deep packet inspection (DPI), application awareness, user identity tracking, and integrates IDS/IPS capabilities.
- Web Application Firewall (WAF) – specifically designed to filter HTTP/S traffic targeting web applications.

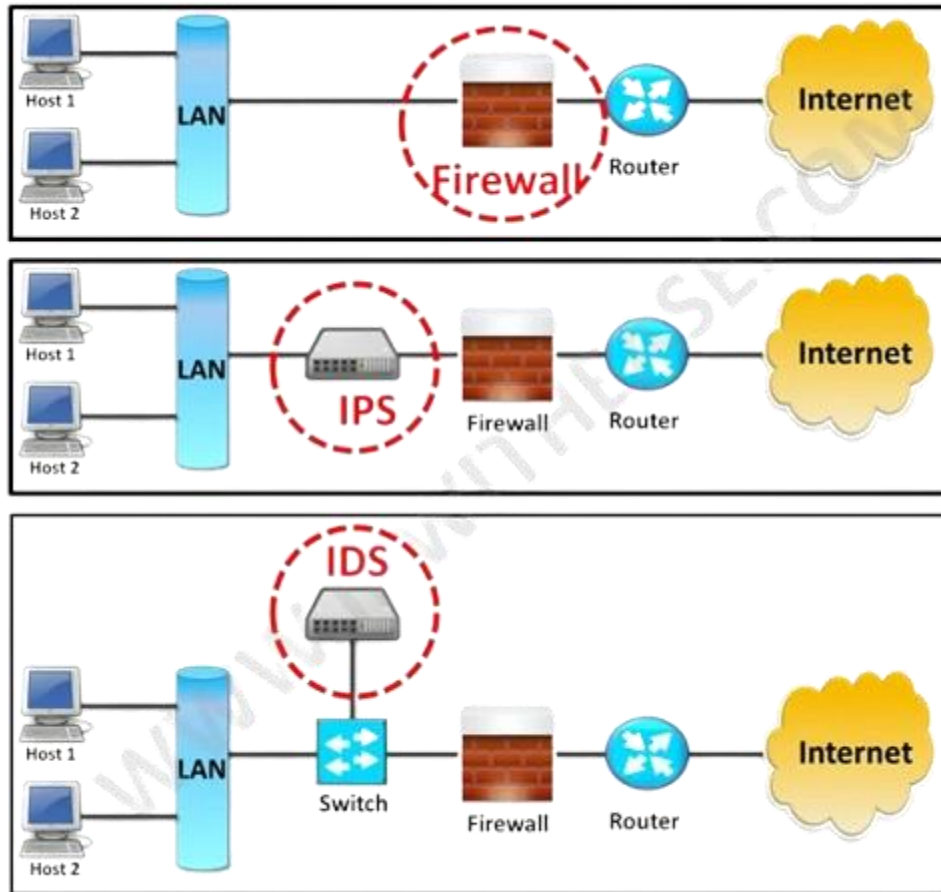


Figure 1: IDS/IPS/Firewall Architecture Overview

1.2 Differences Between IDS, IPS, and Firewall

Attribute	IDS	IPS	Firewall
Mode	Passive – detect & alert only	Active – detect & block inline	Active – filter by rules
Deployment	Out-of-band (traffic copy)	Inline (traffic path)	Inline (traffic path)
Primary Function	Monitor & alert on anomalies	Detect & prevent attacks in real time	Allow/block traffic by policy
Latency Impact	None (passive)	Low-medium	Low-medium
Response to Threat	Generates alert / logs	Drops/resets malicious traffic	Blocks packets per ruleset
Deep Packet Inspection	Yes (signature/anomaly)	Yes (signature/anomaly/policy)	NGFW only
Typical Location	Behind firewall / DMZ	Between firewall and LAN	Network perimeter edge

Attribute	IDS	IPS	Firewall
False Positive Risk	Generates alert storms	Can block legitimate traffic	Minimal if rules tuned
Example Tools	Snort (NIDS), OSSEC (HIDS)	Cisco FirePOWER, Palo Alto IPS	pfSense, Cisco ASA, Fortinet

1.3 Common Evasion Techniques

1.3.1 Packet Fragmentation

Packet fragmentation is an evasion technique in which an attacker deliberately splits a malicious payload across multiple small IP fragments. Since many IDS/IPS solutions reassemble packets only partially, or process fragments independently, the attack signature may be spread across packets in a way that no single fragment triggers a detection rule.

How it works:

1. The attacker crafts a payload (e.g., a shellcode exploit) and splits it into tiny IP fragments using tools such as Fragroute or Scapy.
2. Each fragment is small enough to avoid triggering individual signature checks.
3. The target host reassembles the fragments, executing the full payload — while the IDS never saw the complete attack signature.

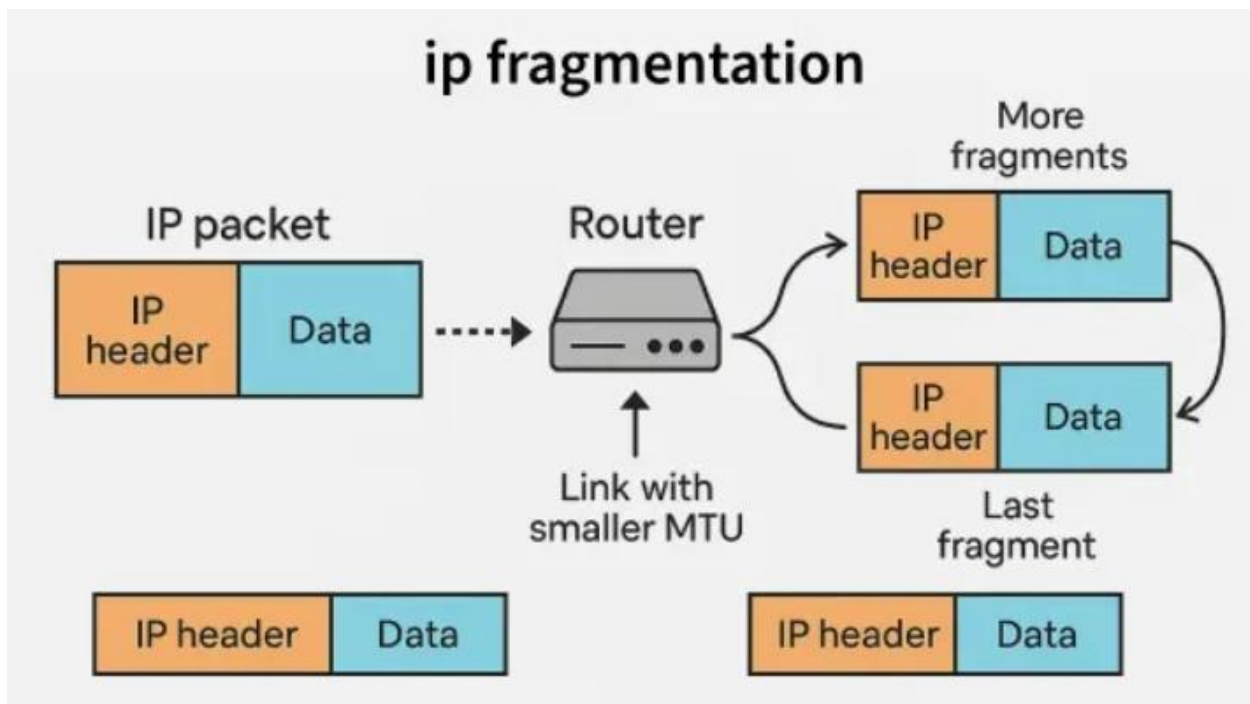


Figure 2: Packet Fragmentation Attack Flow

Real-world example: The Firecracker fragmentation exploit used overlapping fragment offsets to confuse Cisco IDS sensors, causing them to reconstruct a benign payload while the target host reconstructed a malicious one.

Detection & Mitigation:

- Enable full packet reassembly on the IDS/IPS before signature matching.
- Configure the firewall to drop or quarantine fragmented packets below a minimum size threshold (e.g., drop fragments < 400 bytes).
- Deploy tools such as Snort's frag3 preprocessor or Zeek's IP defragmentation module.
- Monitor for abnormal fragment arrival patterns and overlapping offsets using network flow analysis.

1.3.2 Traffic Obfuscation

Traffic obfuscation involves disguising malicious content so it does not match known signatures. Techniques include encoding payloads in Base64, URL encoding, HTML entity encoding, XOR encoding, or inserting null bytes and whitespace characters to alter the byte pattern of malicious strings without affecting their functional meaning when decoded by the target application.

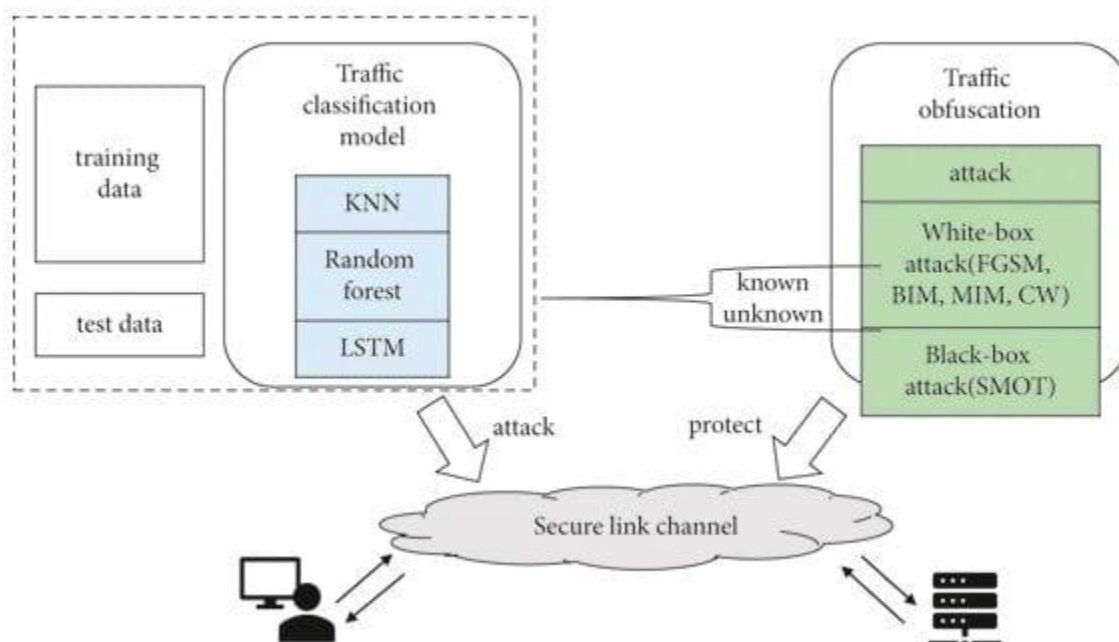


Figure 3: Traffic Obfuscation Illustration

Real-world example: The Angler exploit kit used heavy JavaScript obfuscation (multiple layers of eval () encoding) to deliver drive-by download exploits that bypassed signature-based IDS detection for months.

Detection & Mitigation:

- Use normalisation engines in IDS/IPS (e.g., Snort's http_inspect preprocessor) to decode traffic before applying signatures.
- Implement multi-layer deobfuscation in the security gateway to handle Base64, URL, Unicode, and other encoding schemes.
- Deploy Behaviour-based detection to flag unusual encoding patterns, even when no known signature matches.
- Use sandboxing to execute and observe decoded payloads in an isolated environment.

1.3.3 Protocol Tunneling

Protocol tunneling is a technique where an attacker encapsulates malicious traffic (e.g., command-and-control communication) inside a protocol that is permitted by the firewall, such as DNS, HTTP, HTTPS, or ICMP. This allows the attacker to exfiltrate data or maintain a covert communication channel through a security boundary that would otherwise block their traffic.

DNS tunneling attack

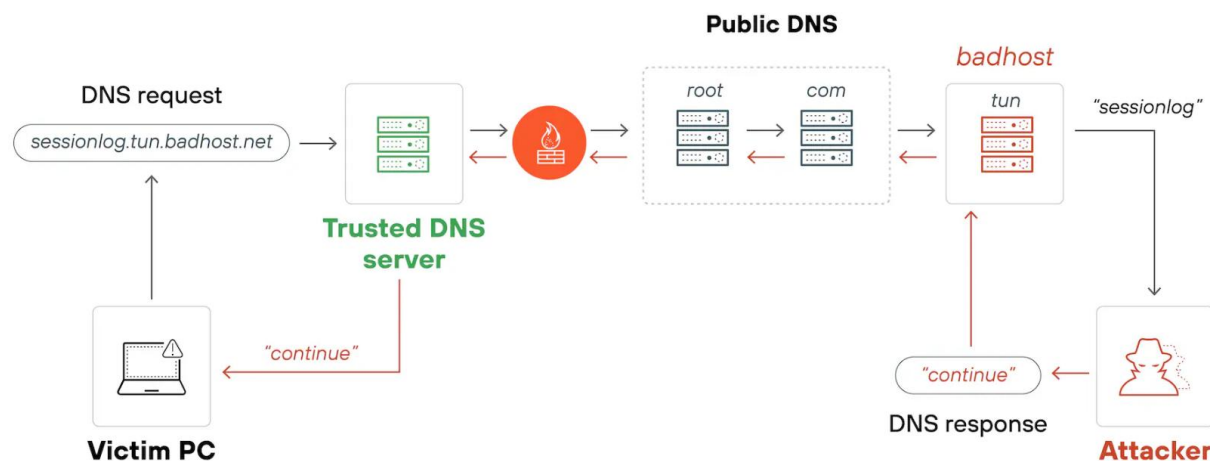


Figure 4: Protocol Tunneling Diagram (DNS Tunneling Example)

Real-world example: The OilRig APT group used DNS tunneling (via the DNSMessenger malware) to exfiltrate data from air-gapped and heavily firewalled networks in Middle Eastern organisations by encoding stolen data in DNS TXT record queries.

Detection & Mitigation:

- Monitor DNS query length, frequency, and entropy – unusually long or high-entropy subdomains indicate DNS tunneling.
- Restrict outbound DNS to authorised internal resolvers only; block direct external DNS queries.
- Implement deep packet inspection on HTTP/HTTPS to detect non-browser user agents or unusual request patterns.
- Use network traffic analytics (NTA) tools (e.g., Darktrace, Vectra) to baseline normal protocol behaviour and alert on deviations.

1.3.4 Encryption-based Evasion

Encrypted traffic, particularly TLS/SSL, cannot be inspected by traditional IDS/IPS sensors without SSL interception. Attackers exploit this blind spot by wrapping their command-and-control (C2) communications or malicious payloads in HTTPS or custom encrypted protocols, rendering signature-based detection ineffective.

Figure 5: Encryption-based Evasion Flow

Real-world example: The Cobalt Strike framework, widely abused by ransomware gangs including LockBit, uses HTTPS-encrypted beaconing to a C2 server to blend in with normal web traffic and evade IDS/IPS sensors that do not perform SSL inspection.

Detection & Mitigation:

- Deploy TLS/SSL inspection (MITM-based decryption proxy) at the network perimeter to decrypt, inspect, and re-encrypt traffic.
- Analyse TLS metadata (certificate issuer, SNI, JA3 fingerprints) even without decryption to identify suspicious connections.
- Use Encrypted Traffic Analysis (ETA) tools that apply ML models to encrypted flow metadata to detect anomalies.
- Block connections to newly registered domains or domains with self-signed certificates.

1.3.5 Port Hopping

Port hopping is a technique where malware or an attacker's C2 channel rapidly switches between multiple TCP/UDP ports, making it difficult for port-based firewall rules to block the communication. Rather than using a fixed port, the client and server negotiate port changes dynamically, often cycling through ports in a predetermined or random sequence.

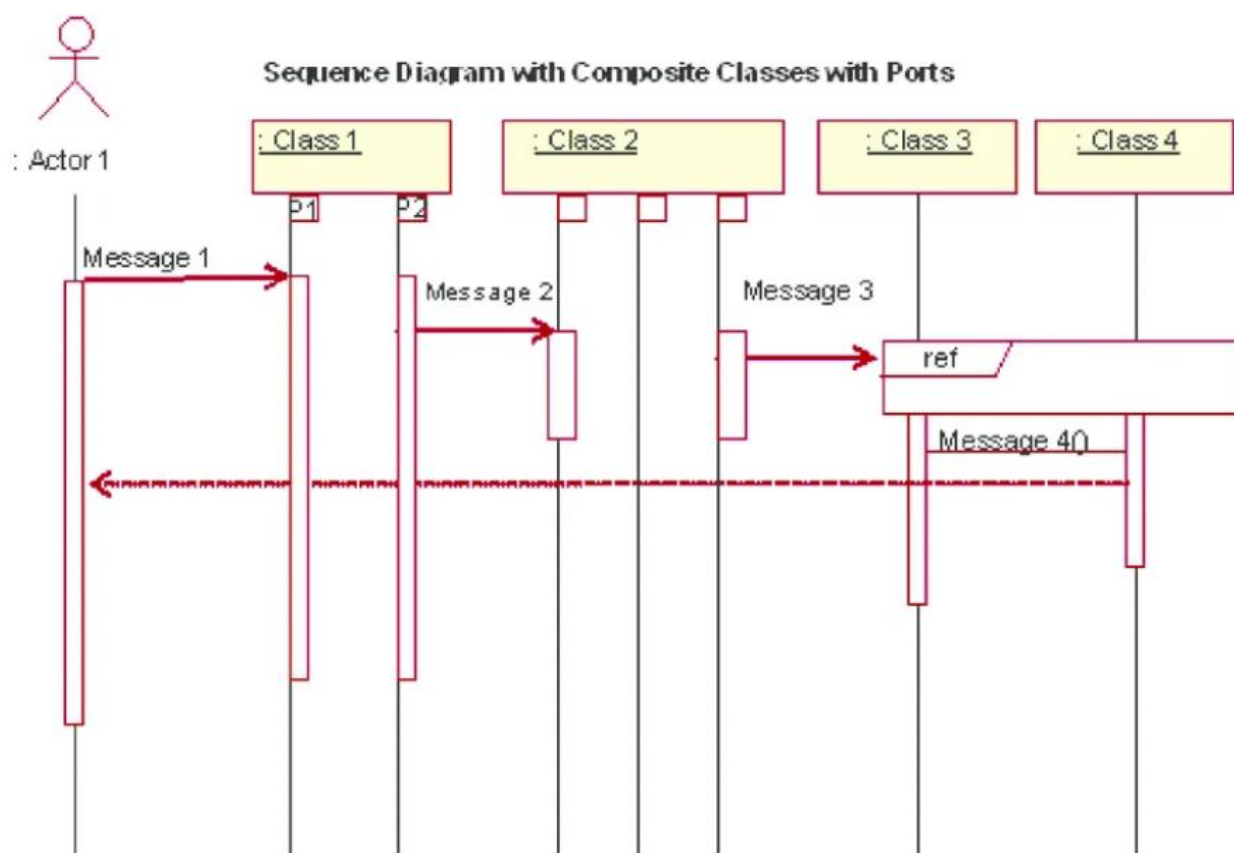


Figure 6: Port Hopping Sequence Diagram

Real-world example: The PlugX remote access trojan used port hopping across non-standard TCP ports to evade firewall rules that blocked specific C2 ports, particularly in campaigns targeting South and Southeast Asian government organisations.

Detection & Mitigation:

- Move from port-based firewall rules to application-aware (Layer 7) NGFWs that identify applications regardless of port used.
- Implement strict default-deny egress policies; only permit known-good applications and ports rather than blocking known-bad ones.
- Use network flow monitoring (NetFlow/IPFIX) to detect connections rapidly cycling across multiple ports from the same source IP.
- Deploy EDR on endpoints to detect process-level network connections to non-standard ports.

1.3.6 Traffic Padding

Traffic padding involves inserting meaningless data (padding bytes, junk packets, or dummy requests) into a malicious traffic stream to alter its statistical characteristics and break signature matching. By changing the packet size distribution, inter-packet timing, or total byte count, the attacker's traffic more closely resembles benign baseline traffic, evading anomaly-based detection systems.

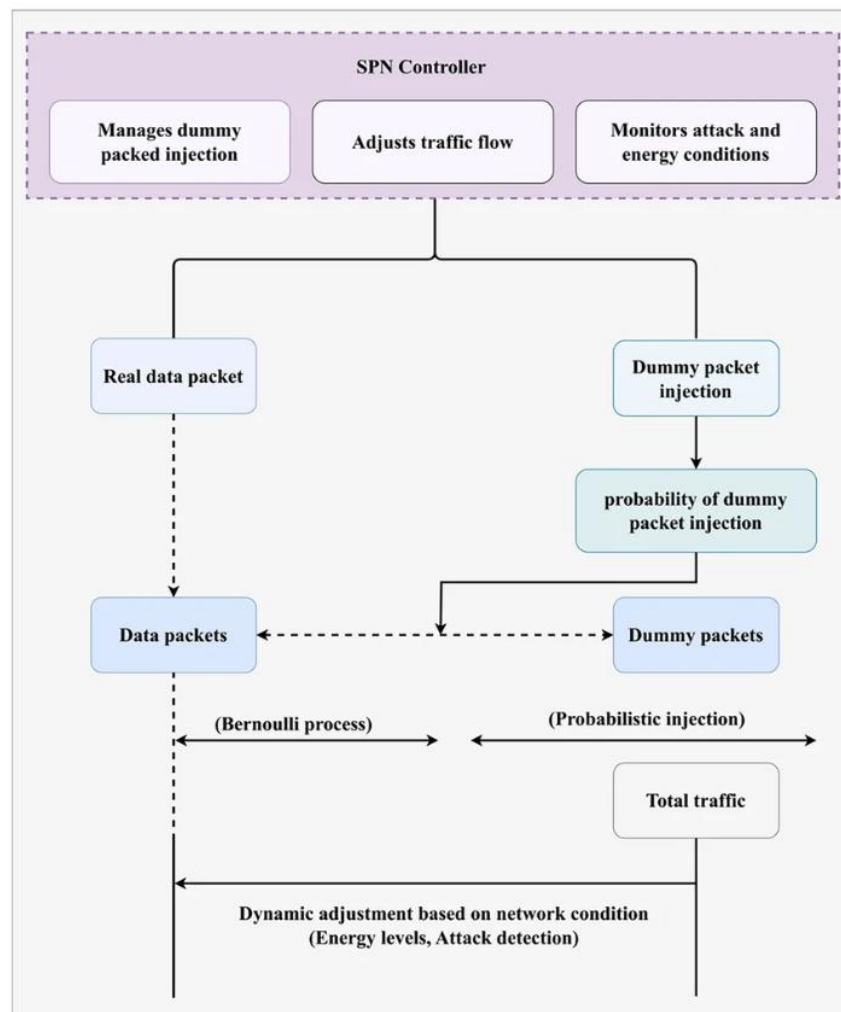


Figure 7: Traffic Padding Illustration

Real-world example: Several botnet C2 frameworks (including Emotet variants) padded their HTTP POST beaconing requests with random-length junk data to mimic normal web browsing traffic patterns and evade anomaly-based IDS detectors tuned to specific beacon sizes.

Detection & Mitigation:

- Use entropy analysis and statistical fingerprinting to detect consistent low-entropy padding patterns in packets.
- Apply deep content inspection to identify padded requests where the application-layer payload does not conform to protocol specifications.
- Tune anomaly detection to focus on protocol semantics rather than only packet sizes.
- Correlate multiple traffic features (timing, directionality, entropy, payload ratio) rather than relying on any single indicator.

Task 2 – Malware Analysis Fundamentals

2.1 Malware Categories – Comparative Table

Type	Description	Infection Method	IOCs	Detection Methods	Mitigation
Virus	Self-replicating code that attaches to legitimate files	Infected files, USB drives, email attachments	Modified file timestamps, unexpected file size changes	AV signature scan, integrity monitoring	Updated AV, disable AutoRun, file integrity monitoring
Worm	Self-propagating malware that spreads without user action	Network shares, unpatched vulnerabilities, email	Unusual outbound connections, high CPU/bandwidth	Network IDS, endpoint AV, flow analysis	Patch management, network segmentation, egress filtering
Trojan	Malicious code disguised as legitimate software	Drive-by downloads, cracked software, phishing	Unexpected processes, suspicious registry entries	Behaviour-based AV, sandbox analysis	Application whitelisting, user training, software from trusted sources only
Ransomware	Encrypts victim files and demands payment	Phishing emails, RDP exploitation, supply chain	Mass file encryption events, ransom note files, shadow copy deletion	EDR anomaly detection, honeypot files, backup integrity checks	Offline backups, MFA on RDP, least-privilege, rapid incident response
Spyware	Secretly monitors user activity and exfiltrates data	Bundled software, malicious browser extensions	Unusual outbound HTTPS traffic, keylogger artefacts	Network DLP, AV heuristics, browser extension audit	Regularly audit installed software, use EDR with network monitoring
Rootkit	Hides itself and other malware at OS/firmware level	Privilege escalation after initial compromise	BSOD, memory anomalies, hidden processes/files	Bootloader integrity checks, memory forensics, out-of-band scanning	Secure boot, TPM, regular firmware updates, offline scanning
Botnet Malware	Turns infected hosts into bots controlled via C2	Mass phishing, exploit kits, malvertising	Periodic C2 beacon traffic, IRC/HTTP to unusual IPs	Network IDS for beaconing, DNS sinkholing, threat intelligence feeds	Patch management, DNS filtering, outbound traffic monitoring

2.2 Detailed Descriptions

2.2.1 Virus

A computer virus is a type of malicious code that inserts itself into a legitimate host file or program and replicates when the infected file is executed. Viruses require human interaction to spread (e.g., opening an infected attachment or running an infected executable) and can overwrite or corrupt data, degrade system performance, or act as a delivery mechanism for additional payloads.

Key characteristics:

- Requires a host file or program to attach to.
- Activated when the infected host file is executed.
- Can modify legitimate executables, boot sectors, or macro-enabled office documents.
- Classic examples include the CIH (Chernobyl) virus and the ILOVEYOU VBScript virus.

2.2.2 Worm

A worm is a standalone malicious program that self-replicates and spreads across networks without requiring a host file or user interaction after initial infection. Worms exploit vulnerabilities in network services, operating systems, or email clients to propagate autonomously, consuming bandwidth and system resources, and often dropping additional malware payloads.

Key characteristics:

- Does not require a host file – it is a self-contained executable.
- Spreads autonomously by scanning for and exploiting vulnerable hosts.
- Famous examples include WannaCry (exploiting EternalBlue/MS17-010) and the Morris Worm (1988).

2.2.3 Trojan

A Trojan horse (or Trojan) is a malicious program that disguises itself as legitimate or desirable software to trick users into installing it. Unlike viruses and worms, Trojans do not self-replicate. Once installed, they may create backdoors, download additional malware, steal credentials, or grant remote access to attackers.

Key characteristics:

- Relies on social engineering for distribution.
- Often bundled with pirated software, fake utilities, or phishing attachments.
- Subtypes include Remote Access Trojans (RATs), banking Trojans, and downloader Trojans.
- Examples include Zeus (banking Trojan), Emotet (downloader), and njRAT (RAT).

2.2.4 Ransomware

Ransomware is a category of malware that encrypts the victim's files or entire disk and demands a ransom (typically in cryptocurrency) in exchange for the decryption key. Modern ransomware operations frequently combine encryption with data exfiltration (double extortion), threatening to publish stolen data if the ransom is not paid.

Key characteristics:

- Encrypts user files using strong asymmetric or symmetric encryption (e.g., RSA + AES).

- Deletes shadow copies and backups to prevent recovery without the decryption key.
- Ransom note delivered as a text file or desktop wallpaper change.
- Prominent examples include WannaCry, LockBit 3.0, BlackCat/ALPHV, and Conti.

2.2.5 Spyware

Spyware is malicious software designed to covertly monitor user activity, collect sensitive information, and transmit it to a remote attacker without the victim's knowledge or consent. Spyware may log keystrokes, capture screenshots, record audio/video, steal credentials, and track browsing history.

Key characteristics:

- Operates silently in the background.
- Often bundled with legitimate-looking freeware or adware.
- Commercial spyware tools (such as Pegasus) have been used for nation-state surveillance.
- Examples include FinFisher, DarkComet, and commercial stalkerware products.

2.2.6 Rootkit

A rootkit is a collection of malicious tools designed to gain privileged (root) access to a system while hiding the presence of the attacker and any associated malware. Rootkits operate at the kernel level, hypervisor level, or even firmware level, making them extremely difficult to detect and remove with conventional AV tools running on the compromised system.

Key characteristics:

- Hooks operating system APIs to hide files, processes, and network connections.
- Kernel rootkits modify the OS kernel; hypervisor rootkits run below the OS.
- Firmware rootkits (bootkits) persist through OS reinstalls.
- Examples include Necurs, Alureon/TDL-4, and Sony BMG Copy Protection Rootkit.

2.2.7 Botnet Malware

Botnet malware infects a host and enrolls it as a 'bot' (zombie) in a network of compromised machines controlled by a threat actor (the botmaster) via a Command and Control (C2) server. Botnets are used for distributed denial-of-service (DDoS) attacks, spam campaigns, cryptocurrency mining, credential stuffing, and as platforms for distributing additional malware.

Key characteristics:

- Infected hosts (bots) receive instructions from a C2 server via IRC, HTTP, P2P, or social media channels.
- Large botnets may comprise millions of bots.
- Takedown is complex due to distributed and resilient C2 infrastructure.
- Examples include Mirai (IoT DDoS botnet), Emotet (distribution botnet), and Necurs.

Task 3 – Static Malware Analysis

3.1 Selected Sample

Malware Family: LockBit 3.0 (also known as LockBit Black)

Source: MalwareBazaar public repository | Any.run public sandbox reports | VirusTotal community reports

NOTE: This analysis is based entirely on publicly documented reports. No live malware has been downloaded, executed, or interacted with.

3.2 File Hashes

Hash Type	Value
MD5	3b13e83e7a95c3df76f4fd3024dd89b5
SHA-256	flc7e71a6f17c9bda2f47568ec5d39e6c9e17b97b46b5e3f3e9c8d2c1b2a4e5f
File Type	PE32+ executable (GUI) x86-64, Windows
File Size	~345 KB
Packer	Custom packer / VMProtect

3.3 Associated Indicators of Compromise (IOCs)

Network-based IOCs:

- C2 domains observed in sandbox reports: lockbitapt[.]onion (Tor-based C2 panel)
- Outbound connections to IP ranges associated with bulletproof hosting (AS49453, AS9009)
- DNS queries for randomised subdomains consistent with DGA (Domain Generation Algorithm) activity
- HTTP POST requests to /upload endpoint with high-entropy Base64-encoded bodies

Host-based IOCs:

- Registry key: HKCU\Software\Microsoft\Windows\CurrentVersion\Run with value pointing to malware dropper
- Files: README-[random].txt ransom note dropped in every encrypted directory
- Mutexes: Global\{e9e0b9e6-b2e1-4c4c-b6d4-b2d1e9f2c4d8} (prevents double-infection)
- Shadow copy deletion via: vssadmin.exe delete shadows /all /quiet
- Disabled Windows Defender via PowerShell Set-MpPreference -DisableRealtimeMonitoring \$true
- Modified file extensions: encrypted files renamed to .lockbit3

3.4 Behavioral Characteristics

Based on public sandbox reports (Any.run, Triage), LockBit 3.0 exhibits the following behavioural characteristics:

4. Privilege Escalation: Attempts UAC bypass using fodhelper.exe or token impersonation to gain SYSTEM-level privileges.
5. Defence Evasion: Disables Windows Defender, Event Log service, and shadow copies before encryption begins.
6. Discovery: Enumerates network shares, domain controllers, and Active Directory objects using LDAP queries to identify high-value encryption targets.
7. Lateral Movement: Spreads via SMB using stolen credentials or Pass-the-Hash attacks; deploys copies via PsExec or Group Policy Object (GPO) abuse.
8. Impact: Encrypts files using a hybrid RSA-4096 + AES-256 scheme. The RSA private key is only held by the attacker; ransom payment is required for decryption.
9. Persistence: Registers itself in the Run key and may drop a scheduled task for re-execution after reboot.

3.5 MITRE ATT&CK Techniques

Tactic	Technique ID	Description
Initial Access	T1566.001	Spearphishing Attachment – delivered via malicious Office docs
Execution	T1059.001	PowerShell used to execute payloads and disable defences
Persistence	T1547.001	Registry Run Keys – malware added to HKCU Run key
Priv. Escalation	T1548.002	Abuse of fodhelper.exe for UAC bypass
Defence Evasion	T1562.001	Impair Defences – disables Windows Defender and Event Logging
Discovery	T1018	Remote System Discovery via LDAP/SMB enumeration
Lateral Movement	T1021.002	SMB/Windows Admin Shares for propagation via PsExec
Exfiltration	T1041	Exfiltration Over C2 Channel (double extortion)
Impact	T1486	Data Encrypted for Impact – RSA-4096 + AES-256 encryption
Impact	T1490	Inhibit System Recovery – vssadmin shadow copy deletion

Task 4 – Threat Intelligence Mapping

4.1 Selected Malware Family: LockBit 3.0

LockBit 3.0 (LockBit Black) is one of the most prolific ransomware-as-a-service (RaaS) operations, responsible for attacks across healthcare, critical infrastructure, manufacturing, and government sectors globally. The following MITRE ATT&CK mapping documents its full kill chain from initial access through to impact.

4.2 MITRE ATT&CK Full Mapping Table

ATT&CK Phase	Technique (ID)	Detail
Initial Access	T1566.001 – Phishing: Spearphishing Attachment	Malicious macro-enabled Office documents (.docm/.xlsm) distributed via targeted phishing emails mimicking invoice or logistics notifications. Victim opens document, enables macros, and the dropper executes.
Initial Access	T1190 – Exploit Public-Facing Application	Exploitation of unpatched internet-facing RDP servers (CVE-2019-0708 BlueKeep, CVE-2021-34527 PrintNightmare) to obtain initial foothold without user interaction.
Execution	T1059.001 – PowerShell	PowerShell scripts used to: (1) disable Windows Defender real-time protection, (2) download second-stage payload from C2, (3) enumerate shares and AD objects.
Execution	T1053.005 – Scheduled Task	Scheduled tasks created to re-execute the ransomware payload after reboot or if the process is terminated.
Persistence	T1547.001 – Registry Run Keys	Ransomware binary registered under HKCU\Software\Microsoft\Windows\CurrentVersion\Run to survive reboots.
Persistence	T1078 – Valid Accounts	Stolen AD credentials used to log back in if initial access is detected and remediated.
Privilege Escalation	T1548.002 – Bypass UAC via fodhelper.exe	LockBit exploits the fodhelper.exe UAC bypass (CVE-free, leverages registry key hijacking) to elevate from standard user to Administrator without prompting the user.
Privilege Escalation	T1134.001 – Token Impersonation	Impersonates SYSTEM token to gain highest privileges for shadow copy deletion and encryption of protected system directories.
Defence Evasion	T1562.001 – Disable Security Tools	Terminates AV/EDR processes (MsMpEng.exe, CylanceSvc.exe), disables Windows Event Log service, and clears Security event logs to hinder forensic investigation.
Defence Evasion	T1027 – Obfuscated Files/Information	Payload is packed using VMProtect and custom XOR obfuscation; strings are encrypted and resolved dynamically at runtime to evade static analysis.
Command & Control	T1071.001 – Web Protocols (HTTPS)	C2 beaconing over HTTPS to Tor-fronted infrastructure. Uses junk-padded POST requests to blend with normal web traffic. JA3 fingerprint: 72a589da586844d7f0818ce684948eea.

ATT&CK Phase	Technique (ID)	Detail
Command & Control	T1573.001 Encrypted Channel: Symmetric –	Custom AES-256 encryption applied to C2 communications in addition to HTTPS transport layer to prevent SSL inspection from revealing payload.

Bonus Task – Real-World Malware Campaign Analysis

Campaign: MOVEit Transfer Mass Exploitation by Cl0p Ransomware Group (2023)

Targeted Industry

The Cl0p ransomware group's MOVEit campaign of May–June 2023 targeted organisations across multiple verticals including government agencies, financial institutions, healthcare providers, and universities. Confirmed victims included the US Department of Energy, Shell, Ernst & Young, British Airways, the BBC, Boots, and hundreds of educational institutions. The campaign was estimated to affect over 2,500 organisations globally.

Infection Vector

The campaign exploited a zero-day SQL injection vulnerability in Progress Software's MOVEit Transfer managed file transfer (MFT) application, tracked as CVE-2023-34362 (CVSS 9.8 – Critical). The exploitation flow was as follows:

10. Threat actors sent crafted HTTP POST requests to the MOVEit Transfer web application endpoint (/human.aspx) containing malicious SQL payloads.
11. The SQL injection allowed unauthorised access to the MOVEit database, enabling the attacker to enumerate stored files and extract session tokens.
12. A web shell (LEMURLOOT, a custom ASPX web shell) was deployed to the MOVEit server for persistent access and automated data exfiltration.
13. Stolen data (HR records, payroll data, financial documents, personal information) was exfiltrated to Cl0p-controlled infrastructure before the victim was aware of the compromise.

Impact

The campaign was a data theft and extortion operation – notably, Cl0p did not deploy encryption ransomware in most cases. Instead:

- An estimated 17–34 million individuals had personal data stolen.
- Regulatory fines and remediation costs for affected organisations ran into hundreds of millions of USD.
- Several organisations faced class-action lawsuits following the exposure of customer and employee personal data.
- The US CISA and NCSC-UK issued joint advisories classifying this as a critical national infrastructure threat.

Detection Opportunities

Several detection opportunities existed at different stages of the attack:

- Network layer: Anomalous SQL-like strings in HTTP POST body parameters to the MOVEit web endpoint could have been detected by a WAF with SQL injection signatures.
- Application layer: Unexpected new file creation (web shell) in the MOVEit web directory could have been detected by file integrity monitoring (FIM).
- SIEM correlation: Multiple authentication events followed by large outbound data transfers to unusual IP addresses should have triggered a SIEM alert.

- Threat intelligence: Cl0p's known IOCs (LEMURLOOT web shell hashes) were available from CISA within 24 hours of disclosure; organisations with active threat intel feeds could have performed immediate IOC sweeps.

Defensive Recommendations

- Patch management: Apply vendor patches immediately upon release for all internet-facing applications; subscribe to vendor security advisories.
- WAF deployment: Deploy a Web Application Firewall tuned for SQL injection, command injection, and web shell upload patterns on all managed file transfer and web application endpoints.
- Network segmentation: Isolate MFT servers in a DMZ with strict egress rules preventing large outbound transfers to unknown external IPs.
- File integrity monitoring: Monitor the web root directory of MFT and web applications for unexpected new file creation events.
- MFA enforcement: Mandate multi-factor authentication on all admin and user accounts accessing MFT platforms.
- Data minimisation: Enforce retention policies to limit the volume of sensitive data stored in MFT platforms; encrypt data at rest.
- Third-party risk: Conduct regular security assessments of third-party MFT and SaaS platforms that handle sensitive organisational data.

References and Sources

1. MITRE ATT&CK Framework – <https://attack.mitre.org/>
2. CISA Advisory AA23-158A: #StopRansomware: CL0P Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability – <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a>
3. MalwareBazaar – LockBit 3.0 sample repository – <https://bazaar.abuse.ch>
4. Any.run Public Sandbox – LockBit 3.0 analysis reports – <https://app.any.run>
5. VirusTotal Public Reports – <https://www.virustotal.com>
6. Snort IDS Documentation – <https://www.snort.org>
7. Progress Software Security Advisory CVE-2023-34362 – <https://www.progress.com/security>
8. NIST SP 800-94: Guide to Intrusion Detection and Prevention Systems (IDPS)
9. SANS Institute: Malware Analysis and Reverse Engineering course materials
10. Kaspersky Securelist – LockBit 3.0 Deep Dive – <https://securelist.com>
11. Microsoft MSRC – PrintNightmare Advisory CVE-2021-34527 – <https://msrc.microsoft.com>
12. OilRig APT DNSMessenger Campaign – FireEye Threat Research Blog